



HACK THE BOX · LINUX

Lame

Informe técnico completo ·
caso RETRO documentado

Máquina Lame resuelta

HTB Lame · 2025-05

Autor	Ramon Santos Sabarich / r4ms4nt
Tipo	Informe técnico completo y archivable
Objetivo	Documentar enumeración, CVE, user y root con trazabilidad clara y reutilizable
Fecha	2025-05



Informe técnico normalizado para archivo, consulta y trazabilidad.

GUÍA DE LECTURA

Índice

Informe técnico final en español, maquetado para archivo, estudio y consulta. Se conserva la cadena real del caso, se distinguen los pasos verificados y se mantiene visible el punto que sigue pendiente de verificar.

- Introducción del caso
- Enumeración inicial
- Validación de la línea VSFTPd
- Enumeración de Samba y selección de la vía principal
- Explotación validada mediante CVE-2007-2447
- Obtención de user.txt
- Obtención de root.txt
- Observaciones técnicas complementarias
- Resumen técnico final
- Lecciones reutilizables

Cadena técnica validada

Enumeración inicial breve.

VSFTPd 2.3.4 identificado y probado sin sesión útil.

Samba 3.0.20 asociado a CVE-2007-2447 como vía principal.

Shell útil obtenida como root.

Lectura posterior de user.txt y root.txt desde contexto privilegiado.

Introducción del caso

Lame es una máquina retirada de Hack The Box documentada como caso RETRO dentro de PENTEST-STUDIO. La cadena técnica validada por la evidencia disponible es breve, pero muy útil desde el punto de vista formativo: enumeración inicial corta, descarte de una vía llamativa pero no productiva, pivote a un servicio legado más sólido y obtención directa de contexto root.

El valor del informe no está en alargar artificialmente la máquina, sino en dejar bien explicados los motivos de cada decisión, qué se observó realmente y qué parte del caso debe seguir marcada como pendiente de verificar.

Nota de precisión importante

La línea VSFTPD 2.3.4 fue enumerada y probada, pero no fue la vía útil de resolución.

La línea Samba 3.0.20 / CVE-2007-2447 sí queda validada como explotación exitosa.

La shell útil resultante corresponde a root, por lo que la lectura de `user.txt` y `root.txt` se realiza ya desde un contexto privilegiado.

La sintaxis exacta del exploit de Samba no quedó preservada de forma textual. El resultado sí está validado, pero ese detalle debe mantenerse como pendiente de verificar.

Enumeración inicial

La enumeración parte de un escaneo de los 1000 puertos TCP más comunes seguido de un filtrado de puertos abiertos. El objetivo de este primer paso no era agotar toda la superficie, sino obtener una lectura rápida de los servicios dominantes.

```
nmap -v -T4 -Pn --top-ports 1000 -oA nmap/top1000_tcp 10.129.56.2
grep open nmap/top1000_tcp.nmap
```

El resultado verificado deja cuatro puertos abiertos: 21/tcp, 22/tcp, 139/tcp y 445/tcp. Con eso la máquina queda organizada en tres líneas de trabajo: FTP, SSH y SMB / NetBIOS.

La evidencia conservada desarrolla dos ramas con peso real: la línea FTP, porque había que validar una versión potencialmente vulnerable, y la línea Samba, porque finalmente es la que conduce a la explotación útil. SSH queda visible, pero no aparece como vía explotada ni como pivote relevante.

La siguiente decisión lógica es identificar versiones en los servicios más prometedores antes de formular cualquier hipótesis de explotación.

Validación de la línea VSFTPD

Con el puerto 21/tcp abierto, el siguiente paso consistió en confirmar la versión exacta del servicio FTP. En este punto, el valor del comando no está en comprobar si el puerto responde, sino en pasar de una intuición general a una hipótesis técnica concreta.

```
nmap -sV -p21 -oA nmap/ftp_version 10.129.56.2
```

La versión detectada fue vsFTPD 2.3.4. Ese dato obliga a comprobar la vía histórica asociada a su backdoor, pero no basta por sí solo para dar la cadena por buena.

```
msfconsole
use exploit/unix/ftp/vsftpd_234_backdoor
set RHOSTS 10.129.56.2
run
```

La evidencia preservada deja una conclusión clara: el exploit se ejecuta, pero no devuelve sesión útil. Eso convierte la línea FTP en una vía probada pero no productiva. Una versión famosa no debe narrarse como la vía principal si la evidencia del caso dice otra cosa.

El descarte práctico de esta rama obliga a volver a la superficie restante y buscar una línea más sólida. Esa línea será Samba.

Enumeración de Samba y selección de la vía principal

Tras comprobar que FTP no proporciona acceso útil, el siguiente servicio dominante es SMB en 139/445. Aquí ya no basta con una prueba ciega: hace falta confirmar versión y obtener contexto adicional.

```
nmap -sV -Pn -p139,445 --script=smb-protocols,smb-os-discovery,smb2-security-mode,s
```

La versión identificada fue Samba 3.0.20. La fuente histórica la asocia de forma explícita con CVE-2007-2447 y anota además la condición relevante del username map script en smb.conf.

A partir de ahí la situación queda bien definida: FTP ya ha sido validado como vía no productiva y Samba aparece con una versión antigua ligada a una vulnerabilidad histórica sólida. Por eso la narrativa correcta del caso es que la vía principal pasa a ser Samba.

Aunque la sintaxis exacta del exploit no se conserva, el enlace entre Samba 3.0.20 y CVE-2007-2447 es lo bastante fuerte como para justificar el pivote técnico sin inventar pasos nuevos.

Explotación validada mediante CVE-2007-2447

El hecho verificado central de esta fase es muy simple y muy importante: tras explotar CVE-2007-2447, la shell obtenida corresponde al usuario root.

Qué sí queda demostrado

La línea de explotación efectiva fue Samba / CVE-2007-2447.

El acceso útil no termina en un usuario limitado.

El contexto de ejecución pasa a ser directamente root.

Pendiente de verificar

No quedó preservado en texto el comando exacto o la sintaxis completa utilizada para lanzar la explotación de Samba en la resolución histórica. El resultado sí está validado y no debe rellenarse con memoria ni con una versión 'típica' del exploit.

Este punto reconfigura la lectura de todo lo que viene después. No existe una fase clásica de obtención de usuario bajo, enumeración local extensa y escalada posterior separada. La explotación útil ya entrega contexto privilegiado, y eso debe reflejarse también en la forma de narrar el caso.

Obtención de user.txt

La lectura de la flag de usuario se documenta como una validación de control sobre el sistema ya comprometido. No es una fase independiente de privilegios bajos, sino una comprobación posterior a la obtención de contexto root.

```
cd /home/makis  
ls -la  
cat user.txt
```

FLAG DE USUARIO

60fc5d64febbdebfe8cc331838bff0b0

Narrar esta fase de manera precisa evita dar a entender que aquí termina una primera mitad del caso. La evidencia no respalda esa lectura: user.txt forma parte del post-acceso privilegiado.

Obtención de root.txt

La flag final se obtiene desde el directorio de administración clásico. Aunque el contexto ya es privilegiado, conviene dejar este paso de forma explícita porque cierra formalmente la resolución documentada.

```
cd /root  
ls -la  
cat root.txt
```

FLAG DE ROOT

c80b43503b56dc7b0dc82643157b4329

Con la lectura de root.txt queda completada la cadena técnica principal. Lo que sigue son observaciones complementarias útiles para entender mejor el comportamiento de algunos servicios.

Observaciones técnicas complementarias

Esta fase no forma parte de la vía principal de acceso, pero sí conserva señales que ayudan a interpretar mejor el caso y a evitar conclusiones precipitadas.

La evidencia histórica conserva esta comprobación local sobre puertos escuchando:

```
netstat -tnlp
```

Resultado anotado: la no accesibilidad externa a ciertos puertos visibles localmente se atribuye a firewall. Un puerto puede aparecer escuchando en local y, aun así, no estar realmente expuesto hacia el exterior.

La fuente anota además que el puerto asociado al backdoor de VSFTPD es 6200 y conserva una verificación adicional:

```
ss -tnlp | grep 6200
```

Resultado anotado: sí escucha. La lectura más prudente es que el comportamiento esperado del backdoor fue observado de forma parcial o transitoria, pero no constituyó la vía útil de acceso final. Por eso el caso sigue debiendo narrarse como una máquina resuelta por Samba, no por FTP.

Resumen técnico final

La cadena real del caso puede resumirse así:

- 1 Enumeración inicial de los 1000 puertos TCP más comunes.
- 2 Detección de puertos abiertos 21, 22, 139 y 445.
- 3 Identificación de vsFTPD 2.3.4 en FTP.
- 4 Prueba de la vía vsftpd_234_backdoor sin sesión útil documentada.
- 5 Identificación de Samba 3.0.20 en 139/445.
- 6 Asociación técnica con CVE-2007-2447.
- 7 Explotación validada con shell resultante como root.
- 8 Lectura de user.txt en /home/makis/user.txt.
- 9 Lectura de root.txt en /root/root.txt.
- 10 Comprobaciones complementarias sobre firewall y sobre el comportamiento del puerto 6200.

Lectura didáctica de conjunto

Lame deja un patrón muy limpio y muy útil para estudio: enumeración corta -> vía famosa inicialmente prometedora -> prueba no productiva -> pivote a servicio legado -> explotación con root directo -> lectura de flags.

El valor principal del caso está en aprender a leer bien la evidencia y a no narrar de forma automática una escalada que la máquina realmente no necesitó.

Lecciones reutilizables

Qué patrón técnico enseña esta máquina

- Enumeración inicial breve pero suficiente para jerarquizar servicios.
- Confirmación de versiones antes de hablar de explotación.
- Descarte explícito de una vía aparente pero no productiva.
- Cambio de foco a un servicio legado más sólido.
- Explotación que entrega contexto root de forma inmediata.

Qué corrige frente a malas lecturas comunes

- No toda versión vulnerable aparente debe asumirse como vía final solo por su fama.
- Hay que separar línea probada de línea realmente explotada.
- Si la shell inicial ya es root, no debe narrarse una escalada posterior inexistente.
- Cuando falta una pieza exacta del exploit, debe marcarse como pendiente de verificar y no rellenarse con memoria o suposición.

Qué aporta al checklist de fase 1

- Anotar siempre la versión exacta del servicio antes de saltar a CVEs.
- Registrar con claridad cuándo una vía queda descartada con evidencia.
- Fijar el contexto del shell inmediatamente después de la explotación.
- Separar obtención de acceso y lectura de flags.